

information. In response to this request, the Administrator submitted a letter dated 25 September 2024, in which it stated that it had taken the necessary actions to notify the affected individual about the data breach. However, the letter did not provide sufficient evidence to demonstrate compliance with the requirements set forth in Article 34 of Regulation 2016/679.

In light of the above, the President of the Personal Data Protection Office, acting under the authority granted by the applicable laws, issued this decision to formally reprimand A Sp. z o.o. sp.k. for failing to promptly notify the affected individual about the data breach, as required by Article 34 of Regulation 2016/679.

This decision is subject to appeal in accordance with the provisions of the Code of Administrative Procedure. The appeal should be submitted to the President of the Personal Data Protection Office within 14 days from the date of delivery of this decision.

The decision shall be communicated to A Sp. z o.o. sp.k. and published on the website of the Personal Data Protection Office.

Warsaw, 17 December 2024

President of the Personal Data Protection Office

[Signature]

[Name]

[Title]

****Information, pursuant to Article 34(2) in conjunction with Article 33(3) of Regulation 2016/679.****

In response, in a letter dated September 25, 2024, the Administrator indicated that "upon discovering the incident, the administrator notified the data subject by telephone and via electronic mail, as indicated in the attached prints" and "the breach was of a singular and limited nature, and furthermore, due to the actions taken to prevent further unauthorized disclosure of data and due to the public nature of some of the data involved in the incident, the breach did not result in a high risk of infringement of the rights or freedoms of natural persons." Additionally, the Administrator attached screenshots of the emails sent to the individual affected by the personal data breach to this letter. Given that the Administrator included the same screenshots in the aforementioned letter that had already been provided in attachments to letters dated March 6 and June 17, 2024, the President of the Personal Data Protection Office initiated, by letter dated October 10, 2024, an administrative proceeding ex officio against the Administrator regarding the failure to notify the data subject of the personal data breach. The Administrator responded in writing to the identified breach of personal data protection regulations, which is the subject of the administrative proceeding mentioned in the notification of the initiation of the proceeding, and in letters dated October 21, 2024, November 15, 2024, and December 6, 2024, provided explanations regarding the aforementioned personal data breach and presented the content of the renewed notification of the personal data breach addressed to the data subject. The notification attached to the letter dated November 15, 2024, directed to the individual affected by the breach, contained all the information specified in Article 34(2) in conjunction with Article 33(3)(b), (c), and (d) of Regulation 2016/679.

****In this factual state, after reviewing all the evidence collected in the case, the President of the Personal Data Protection Office considered the following:****

****I. Breach of Article 34(1) and (2) of Regulation 2016/679.****

According to Article 34(1) of Regulation 2016/679, if a personal data breach may result in a high risk of infringement of the rights or freedoms of natural persons, the administrator shall notify the data subject of such a breach without undue delay. Article 34(2) of Regulation 2016/679 states that the notification referred to in paragraph 1 of this article shall describe the nature of the personal data breach in clear and plain language and shall at least contain the information and measures referred to in Article 33(3)(b), (c), and (d) of Regulation 2016/679. Therefore, the notification, in addition to describing the nature of the personal data breach, should include:

- the name and contact details of the data protection officer or other contact point from which more information can be obtained;
- a description of the possible consequences of the personal data breach;
- a description of the measures taken or proposed by the administrator to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

As a result of the analysis of the personal data breach reported by the Administrator, taking into account the nature of the breach, its duration, the categories of data, the number of individuals affected by the breach, and the remedial measures taken, the President of the Personal Data Protection Office concluded that the breach of data confidentiality, particularly of data concerning names, addresses of residence or stay, email addresses, PESEL identification numbers, series and numbers of identity cards, and telephone numbers, poses a high risk of infringement of the rights or freedoms of natural persons. Consequently, it is necessary to notify the data subject of the breach of their personal data and to provide them with all the information specified in Article 34(2) of Regulation 2016/679.

It should be emphasized that in a situation where a personal data breach results in a high risk of infringement of the rights or freedoms of natural persons, the Administrator is obliged, under Article 34(1) of Regulation 2016/679, to notify the data subject of such a breach without undue delay. This means that the administrator is required to implement all appropriate technical and organizational measures to immediately identify the personal data breach and quickly inform the supervisory authority, and in cases of high risk of infringement of rights or freedoms, also the data subject. The Administrator should fulfill this obligation as quickly as possible.

Recital 86 of Regulation 2016/679 explains: "The administrator should without undue delay inform the data subject of a personal data breach if it may result in a high risk of infringement of the rights or freedoms of that person, so as to enable that person to take the necessary protective measures. Such information should include a description of the nature of the personal data breach and recommendations for the data subject on minimizing potential adverse effects. Information should be communicated to the data subjects as soon as reasonably possible, in close cooperation with the supervisory authority, respecting the guidance provided by that authority or other relevant bodies, such as law enforcement authorities. For example, the need to minimize the immediate risk of harm will require the prompt notification of the data subjects, while the implementation of appropriate measures against similar or... similar violations of data protection may justify subsequent notification."

As indicated by the Guidelines of the European Data Protection Board (hereinafter: "EDPB") No. 9/2022[1], adopted on March 28, 2023, hereinafter referred to as Guidelines 9/2022, a personal data breach may potentially lead to a number of negative consequences for individuals whose data is the subject of the breach. Among the possible consequences of a breach, the EDPB lists: physical harm, material or non-material damages. Examples of such damages include, among others: discrimination, identity theft or identity fraud, financial losses, damage to reputation, breach of confidentiality of personal data, and significant economic or social harm. In this case, there is no doubt that due to the scope of the data covered by the personal data breach, including the PESEL identification number, there is a high probability of the occurrence of the aforementioned damages, which means that the above-mentioned personal data breach is associated with a high risk of infringement of the rights or freedoms of individuals. It is also beyond doubt that the scope of the data covered by the breach allows for the unequivocal identification of the individual to whom the data pertains.

First and foremost, it should be emphasized that the data breach in question involved the PESEL identification number, which is an eleven-digit numerical symbol that unequivocally identifies an individual, containing, among other things: date of birth and gender designation, and thus is closely linked to the private sphere of the individual and is also subject to, as a national identification number, exceptional protection under Article 87 of Regulation 2016/679 – being data of a special nature and requiring such special protection. The PESEL number serves as identifying data for each individual and is commonly used in dealings with various institutions and in legal transactions. The PESEL

number, along with the first name and surname, unequivocally identifies an individual in a way that allows for the attribution of negative consequences of the breach (e.g., identity theft, loan fraud) to that specific individual. Such a combination of data may be sufficient for “impersonating” the data subject and incurring obligations in the name and to the detriment of that subject, e.g., financial obligations (see: <https://www.bik.pl/poradnik-bik/wyludzenie-kredytu-tak-dzialaja-oszusci> - where a case is described in which: “Only the first name, surname, and PESEL number were enough for the fraudsters to defraud several loans totaling tens of thousands of zlotys. Nothing else matched: neither the ID number nor the residential address”). In assessing the risk, the key factor is the type and sensitivity of the personal data disclosed as a result of the breach. The Guidelines 9/2022 emphasize that a collection of various personal data typically has a more sensitive nature than individual data.

It is worth citing one of the examples found in the EDPB Guidelines No. 01/2021[2] (case No. 14, p. 31), referring to the situation of “accidentally mailing highly confidential personal data.” In the case described in the aforementioned guidelines, there was a disclosure of a social security number, which is equivalent to the PESEL number used in Poland. In this case, the EDPB had no doubt that the disclosed data, including: first name and surname, email address, postal address, and social security number, indicated a high risk of infringement of the rights or freedoms of individuals (“the involvement of their [the affected individuals] social security number, as well as other, more basic personal data, additionally increases the risk, which can be described as high”). The EDPB recognizes the importance of national identification numbers (in this case, the PESEL number), while emphasizing that such a breach of personal data protection, thus encompassing data in the form of: first name and surname, email address, postal address, and social security number, requires the implementation of actions, i.e.: notifying the supervisory authority and informing the individuals whose data are affected about the breach.

The European Data Protection Board therefore has no doubt that an individually assigned number that unequivocally identifies an individual should be subject to special protection, and its disclosure to unauthorized entities may be associated with a high risk of infringement of the rights or freedoms of individuals.

The fact that data that unequivocally identifies an individual may cause a high risk of infringement of rights or freedoms is also indicated by the EDPB in other examples provided in the Guidelines 01/2021. In points 65 and 66 of the Guidelines 01/2021, it is stated: “(...) The breached data allow for the unequivocal identification of the individuals to whom the data pertain and contain other information about them (including gender, date and place of birth), furthermore, they may be used by an attacker to guess customer passwords or to conduct a spear phishing campaign targeting bank customers. For these reasons, it was deemed that the data breach is likely to result in a high risk of infringement of the rights and freedoms of all individuals whose data are affected. Consequently, material damages (e.g., financial losses) and non-material damages (e.g., identity theft or fraud) may occur.”

Similar doubts (that the disclosure of the PESEL number along with other personal data may cause a high risk of infringement of the rights or freedoms of individuals) were also held by the Provincial Administrative Court in Warsaw, which in its judgment of September 22, 2021, case No. II SA/Wa 791/21, stated that “There is no doubt that the examples of damages cited in the guidelines may occur in the case of individuals whose personal data – in some cases including the PESEL identification number or the series and number of the identity card – have been recorded on the shared recordings. Not

of the person whose data has been compromised, is irrelevant for such an assessment. Furthermore, the Court in the cited ruling indicated that “the data was made available to unauthorized persons, which means that a security breach occurred leading to the unauthorized disclosure of personal data, and the scope of this data, which in some cases also includes the PESEL identification number or the series and number of the identity card, determines that there is a high risk of violation of the rights or freedoms of natural persons.” Considering the above issues, it is also necessary to refer to the position of the Provincial Administrative Court in Warsaw expressed in the judgment of July 1, 2022, in case no. II SA/Wa 4143/21. In the justification of this judgment, the Court stated that: “It should be agreed with

the President of UODO that the loss of confidentiality of the PESEL number in conjunction with personal data, such as: first name and surname, registered address, bank account numbers, and the identification number assigned to Bank clients - CIF number, is associated with a high risk of violation of the rights or freedoms of natural persons. In the case of a breach of such data as first name, surname, and PESEL number, identity theft or forgery is possible, resulting in negative consequences for the individuals concerned. Therefore, the Bank in this matter should have promptly, in accordance with Article 34(1) of the GDPR, notified the individuals concerned about the breach of personal data protection, so as to enable them to take necessary preventive actions" (emphasis added). It should also be noted the judgment of August 31, 2022, case no. II SA/Wa 2993/21, in which the Provincial Administrative Court in Warsaw emphasized that "(...) the authority rightly assumed that there was a high risk of violation of the rights and freedoms of individuals affected by the breach due to the possibility of easy identification of the individuals whose data was compromised based on the disclosed data. This data includes first name and surname, correspondence address, phone number, and PESEL number of individuals holding Polish citizenship. In this situation, the administrator was obliged to notify without undue delay the individuals concerned about the breach." Similarly, the Provincial Administrative Court in Warsaw expressed itself in judgments of November 15, 2022, case nos. II SA/Wa 546/22, June 21, 2023, case no. II SA/Wa 150/23, and November 6, 2023, case no. II SA/Wa 996/23. Meanwhile, the Supreme Administrative Court in its judgment of December 6, 2023, case no. III OSK 2931/21, indicated that "the President of UODO correctly established that there was a disclosure of data, including first names and surnames, as well as PESEL numbers of natural persons, and thus relatively permanent, unchanging data, the disclosure of which can always pose a risk of negative consequences for the aforementioned individuals. Similarly, addresses of residence are personal data, the unauthorized disclosure of which creates a probability of a high risk of negative legal consequences (...)."

According to the infoDOK report[3] (which is prepared as part of the social Information Campaign of the RESTRICTED DOCUMENTS System, organized by the Polish Bank Association and some banks, under the patronage of the Ministry of Internal Affairs and Administration and in cooperation with, among others, the Police and the Consumers' Federation), in the third quarter of 2024, there were 3,373 attempts to defraud loans and credits, amounting to PLN 81.7 million. Over the last twelve months, the total amount of thwarted attempts to defraud loans is PLN 332.5 million. Furthermore, it should be noted that, for example, in the fourth quarter of 2022, there were 2,269 attempts to defraud loans and credits, amounting to PLN 40.2 million[4]. This indicates a significant increase in attempts to defraud loans and credits during the reported period.

Moreover, as indicated by court rulings, judgments in cases of loan fraud are not uncommon and have been issued by Polish courts in similar cases for a long time. For example, one can refer to the judgment of the District Court in Łęczyca of July 27, 2016 (case no. I C 566/15), in which fraudsters taking a loan using someone else's data used a PESEL number, a fictitious address, and an incorrect (invalid) identity card number. In the justification of the aforementioned judgment, the Court stated that: "The conducted evidentiary proceedings and analysis of the documents submitted by the plaintiff lead to the conclusion that it can be unequivocally stated that in the case under consideration, the defendant was not a party to the loan agreement concluded on May 5, 2014. Although the PESEL number of the defendant J. R. was used when concluding it, the indicated place of residence does not correspond to the place of residence of the defendant. The defendant J. R. has never lived in W. The loan amount was transferred to an account that was not owned by the defendant. At the time of concluding the loan agreement, the identity card no. (...) had expired on March 15, 2014. The mobile phone number indicated in the loan agreement and its attachments does not match the actual phone numbers used by the defendant."

In another case (I C 693/16), the District Court in Zgierz in its judgment of November 4, 2016, ruled: "The personal data of the defendant in the form of his first name and surname and PESEL number, which were consistent with the data of the defendant, did not indicate that the defendant made a declaration of will to conclude a loan agreement on December 17, 2014. It is possible that a person

who unlawfully obtained access to the personal data of the defendant concluded a loan agreement on his behalf with the company (...) sp. z o.o. S.K.A. based in W. In this case, the defendant demonstrated that he had never lived at the address indicated in the loan agreement and that the phone number and email address used to register on the website and submit the loan application belonged to him."

Cases related to loan fraud, where unknown individuals usually only have the first name and surname of the person whose data has been compromised, are common. and the correct PESEL number (the other data is false), there are still many cases, as confirmed by the judgments issued by the courts in these matters. Below are a few examples:

- Judgment of the District Court for Łódź-Widzew in Łódź dated August 13, 2020, in case file no. II C 1145/19, in which an unknown third party unlawfully obtained the defendant's PESEL number and identity card number, while the other address data indicated in the loan agreement was false. "In the Court's opinion, the evidence offered by the defendant – especially the documents from the criminal case pending before the District Court in Tarnowskie Góry under case file no. VI K 383/16 – indicates that the loan agreement dated November 8, 2014, was concluded by a third party using some personal data of Z. A. They provided a false residential address, under which the defendant never lived, and the loan amount was transferred to a bank account that did not belong to Z. A. [...] and the identity card number provided in this agreement was a number that the defendant no longer used at the time of the loan agreement, as this document had expired about 8 months earlier";

- Judgment of the District Court in Pisz dated August 21, 2020, case file no. I C 260/20 – "[...] The Court found that when concluding the subject agreement, the defendant's data was unlawfully used and entered as the borrower's data, while the defendant was not a party to the agreement. The defendant's position is confirmed by the notification he submitted regarding the commission of fraud to his detriment, as well as by the fact that the prosecutor's office is conducting proceedings in this matter against the person indicated by the defendant. It should be noted that also in the ongoing proceedings before this court regarding payment case files no. I C 1/19 and I C 482/19, where E. M. also appeared as the defendant, and where financial obligations were incurred in his name and surname under the same circumstances as in this proceeding, final judgments dismissing the claim were also issued. In the Court's opinion, the circumstances of the agreement with the plaintiff, where the first name and surname of the borrower and his PESEL number are identical, while there is a discrepancy regarding the other data resulting from the content of the defendant's identity card, i.e., the series and number of this document, residential address, taking into account the fact that a criminal process is being conducted against the person who allegedly impersonated the defendant to conclude agreements remotely and incur financial obligations in various institutions, clearly indicate that it was not the defendant who concluded the loan agreement no. (...) with the plaintiff's legal predecessor";

- Judgment of the District Court in Puławy dated April 7, 2022, in case file no. I C 475/19, in which the Court unequivocally stated that "[...] the evidence allowing for the verification of the defendant as a party to the subject agreement is not constituted solely by the indication of his personal data: first name, surname, PESEL number, as well as the series and number of the identity card in the content of the agreement – especially in a situation where the loan is concluded via an online platform, and thus it is obvious that the lender does not have the possibility of direct verification of the identity of the other party, and the agreement itself is not confirmed by the borrower's signature."

It should also be noted that the proper execution by the Administrator of his obligation arising from Article 34(1) of Regulation 2016/679, related, among other things, to the necessity of providing without undue delay within the notification of a personal data breach all required information, in accordance with Article 34(2) in connection with Article 33(3) of Regulation 2016/679, cannot be conditional on the occurrence of a violation of the rights or freedoms of that person as a result of the materialization of possible negative consequences of the breach (cf. judgments of the Provincial Administrative Court in Warsaw dated September 22, 2021, case file no. II SA/Wa 791/21, dated July 1, 2022, case file no. II SA/Wa 4143/21, dated August 31, 2022, case file no. II SA/Wa 2993/21, dated November 15, 2022, case file no. II SA/Wa 546/22, and dated April 26, 2023, case file no. II SA/Wa 1272/22).

It is worth emphasizing that when assessing the risk of violation of the rights or freedoms of natural persons, which is a condition for notifying the individuals whose data are concerned, both the probability factor and the severity of potential negative consequences must be taken into account. A high level of either of these factors affects the overall assessment, which determines the fulfillment of the obligations specified in Article 34(1) of Regulation 2016/679. Given that due to the scope of the disclosed personal data in the analyzed case, there was a possibility of serious negative consequences materializing for the person whose data are concerned (as demonstrated above), the weight of the potential impact on the rights or freedoms of natural persons should be considered high. At the same time, the probability of a high risk occurring as a result of the breach in question is not small and has not been eliminated. Therefore, it should be stated that in connection with the breach in question, there was a high risk of violation of the rights or freedoms of the person whose data are concerned, which consequently determines the obligation to notify the person whose data are concerned about the breach.

In Guidelines 9/2022 EROD, indicating the factors to be considered when assessing risk, reference is made to recitals 75 and 76 of Regulation 2016/679, which suggest that the administrator should take into account both the probability of occurrence and the severity of the threat to the rights or freedoms of the person whose data are concerned. In the case of a personal data breach, the administrator should focus on the risk of the impact of the breach on the individual resulting from the breach. Thus, when assessing the risk

for a natural person resulting from a breach of personal data protection, the administrator should take into account the specific circumstances of the breach, including the severity of the potential impact and the likelihood of its occurrence. In this regard, when assessing the risk, the EROD recommends considering criteria such as: the type of breach, the nature, sensitivity, and quantity of personal data, as well as the ease of identification, as these may affect the level of risk to individuals. The risk of a breach of the rights and freedoms of a natural person, according to Guidelines 9/2022, will be greater when the consequences of the breach are more serious, as well as when the likelihood of their occurrence increases.

Referring the above to the case at hand, it should be noted that due to the scope of personal data covered by the breach of personal data protection reported by the Administrator to the supervisory authority, which caused a high risk of violation of the rights or freedoms of natural persons, he was obliged to notify without undue delay the person to whom the data relates about the breach of personal data protection, in accordance with the requirement arising from Article 34(1) and (2) of Regulation 2016/679, which he did not do. The screenshots submitted by the Administrator attached to the letters dated March 6 and June 17, 2024, containing emails directed to the aforementioned person did not include any of the elements required by these provisions of Regulation 2016/679. The proper notification of this person about the breach of personal data protection occurred only on November 14, 2024 (the date of sending the letter), thus after the initiation of administrative proceedings in this matter by the President of UODO and more than 3 years after the occurrence of this breach. Therefore, it cannot be accepted that the Administrator notified the person to whom the data relates about the breach of her personal data protection without undue delay, which constitutes a violation of Article 34(1) and (2) of Regulation 2016/679.

When applying the provisions of Regulation 2016/679, one must keep in mind the purpose of this regulation (expressed in Article 1(2)), which is to protect the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data. Furthermore, the protection of natural persons in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In case of any doubts, for example, regarding the fulfillment of obligations by administrators - including in situations where there has been a breach of personal data protection - these values should be taken into account first.

It should be emphasized that by notifying the data subject without undue delay, the administrator enables them to take necessary preventive actions to protect their rights or freedoms from the negative effects of the breach. Article 34(1) and (2) of Regulation 2016/679 aims not only to ensure the most

effective protection of the fundamental rights or freedoms of data subjects but also to implement the principle of transparency, which arises from Article 5(1)(a) of Regulation 2016/679 (see W. Chomiczewski [in:] GDPR. General Regulation on Data Protection. Commentary. ed. E. Bielak - Jomaa, D. Lubasz, Warsaw 2018). Proper fulfillment of the obligation specified in Article 34 of Regulation 2016/679 is intended to provide the person to whom the data relates with quick and transparent information about the breach of the protection of their personal data, along with a description of, among other things, the measures they can take to minimize its potential negative effects. By acting in accordance with the law and demonstrating care for the interests of the person to whom the data relates, the Administrator should have ensured this person the best possible protection of their personal data without undue delay.

II. Justification for issuing a reprimand.

Based on Article 58(2)(b) of Regulation 2016/679, under which each supervisory authority has the right to issue a reprimand to the administrator or processor in the course of its proceedings in the event of a breach of the provisions of this regulation by processing operations, the President of UODO deemed it justified to issue a reprimand to the Administrator regarding the identified breach of the provisions of Article 34(1) and (2) of Regulation 2016/679. Recital 148 of Regulation 2016/679 states that in order for the enforcement of the provisions of the regulation to be more effective, sanctions, including administrative fines, should be imposed for its violation - in addition to or instead of appropriate measures imposed under this regulation by the supervisory authority. If the breach is minor, the monetary penalty may be replaced by a reprimand. However, due attention should be paid to the nature, gravity, and duration of the breach, whether the breach was not intentional, the actions taken to minimize the damage, the degree of responsibility, or any relevant previous breaches, the manner in which the supervisory authority became aware of the breach, compliance with measures imposed on the administrator or processor, adherence to codes of conduct, and any other aggravating or mitigating factors.

The President of UODO concluded that in the established circumstances of this case, issuing a reprimand to the Administrator regarding the identified breach of the provisions of Article 34(1) and (2) of Regulation 2016/679 is a sufficient measure. The lack of notification to the person whose data was breached is, after all, a one-time event, and thus we are not dealing with systematic action or inaction that would pose a serious threat to the rights or freedoms of individuals whose personal data are processed by the Administrator. Furthermore, the Administrator ultimately fulfilled the obligation to notify the person to whom the data relates about the breach of the protection of her personal data, providing her with all the information specified in the aforementioned provisions of Regulation 2016/679. At the same time, the issuance of a warning, in the opinion of the President of the UODO, will also ensure that similar incidents do not occur in the future. However, should a similar incident occur again in the future, any warning issued by the President of the UODO against the Administrator will be taken into account when assessing the grounds for the potential imposition of an administrative monetary penalty, in accordance with the principles set out in Article 83(2) of Regulation 2016/679.

In this factual and legal situation, the President of the Office for Personal Data Protection has ruled as stated in the operative part.

[1] Guidelines 9/2022 on the notification of a personal data breach under the GDPR Version 2.0, adopted on March 28, 2023.

[2] Guidelines of the European Data Protection Board 01/2021 on examples regarding the notification of a personal data breach adopted on December 14, 2021, version 2.0 (hereinafter "Guidelines 01/2021").

[3] <https://www.zbp.pl/getmedia/9e009ac5-d5bb-4d22-80fd-bf70a4457b71/infodok-2024-07-09-wydanie-59>;

[4] <https://www.zbp.pl/getmedia/6fdef6c1-3d63-43f6-a992-179a333455c7/infodok422>;

Print article

Metadata

Entity providing the information:

Department of Control and Violations

Information created by:

Mirosław Wróblewski

2024-12-17

Information entered by:

Wioletta Golańska

2025-01-30 14:47:03

Last modified by:

Agnieszka Kaczor

2025-01-31 11:30:47